Compliance and Governance: GRC Layer with Cloud Scanner Evidence

Objective

The Compliance and Governance layer should act as the central GRC system that converts technical security findings into control status, risk visibility, remediation ownership, and audit-ready evidence. Instead of keeping scanner results, manual evidence, DPDP inputs, and audit notes in separate files, the GRC layer should normalize them into one control-oriented view.

Key Highlights

- Generic GRC platforms help manage policies, controls, risks, audits, evidence, exceptions, and remediation tasks in one place.
- CloudGuard can work as a technical evidence source for the GRC platform by scanning AWS, GCP, Kubernetes, and IaC files.
- Evidence should come from multiple security streams: LogManthan for security monitoring/threat response, Omjee/Vivek scanners for infrastructure security, manual asset inventory plus scanner inputs, Prudhvi SAST and Anish DAST/Burp findings for web application security, Keycloak/open-source IAM data for identity controls, and DPDP inputs from Pratik/Shaswati.
- The GRC layer should not only show vulnerabilities; it should map each finding to controls such as DPDP, ISO 27001, CIS, NIST, OWASP, Kubernetes benchmark, and internal policies.
- The most important design principle is traceability: every risk should link back to a source system, evidence artifact, asset, owner, severity, remediation status, and timestamp.

Technical Summary

The proposed architecture uses a connector-based evidence pipeline. Each scanner or source system sends normalized findings to an ingestion API. The ingestion layer validates the payload, stores raw evidence in object storage, stores metadata and control mappings in PostgreSQL, and updates the compliance dashboard. CloudGuard already supports a similar model through scanner jobs, evidence artifacts, a PostgreSQL-backed queue, object storage, and dashboard/report endpoints.

Core components:

- Evidence sources: Cloud scanners, IaC scanner, Kubernetes scanner, SAST, DAST, Burp Suite, infrastructure scanners, LogManthan logs, asset inventory, IAM/Keycloak data, and DPDP evidence.
- Connector layer: Converts different outputs into a common evidence schema.
- Ingestion API: Validates source, scanner type, evidence type, user or tenant context, checksum, and metadata.

- Storage: PostgreSQL for normalized findings and object storage for raw evidence files.
- GRC dashboard: Shows control status, non-compliance, evidence count, critical/high findings, remediation owner, and audit history.
- Reporting: Generates executive, audit, and technical reports.

Proposed Setup

For the PoC, the system can run as a Docker Compose stack on a VM using Dokploy. Dokploy can provide HTTPS, subdomain routing, deployment workflow, logs, and service management. Recommended public routes are `app.cloudscanner.com` for the dashboard, `api.cloudscanner.com` for API access, and `ingest.cloudscanner.com` for evidence ingestion. The scanner jobs should remain decoupled from the portal through worker containers so heavy scans do not block the dashboard.

Expected Output

The final outcome is a GRC dashboard where leadership can see compliance posture, auditors can review evidence, and technical teams can act on remediation. This gives a single governance view across cloud security, infrastructure security, web application security, identity and access security, asset inventory, threat monitoring, and DPDP compliance.